調達担当者に届く形で、セキュリティの判断を渡す。

BabushkaSec は、認証・API・クラウド構成の設計レビューを「公表資料 → 仕様書 → 設定 → コード → 実行結果」の5階層に降りて行う、独立系のアドバイザリーです。この資料は、発注の判断と社内の稟議にそのまま使える情報を目的にまとめています。

経営層・情報システム・調達法務向け　全13ページ / A4 横　オンライン版 security.babushkai.com/proposal/　OAuth 2.0 / OIDC・Web API・クラウド構成

資料の構成／13 枚

01 表紙
02 30秒で
03 前提
04 深さ
05 依頼の形
06 進め方
07 ご負担
08 委託先管理
09 道具と境界
10 証明
11 向いていない仕事
12 社内調整
13 次の一歩

要点は、この4つです。

読み進める前に、判断に必要な数字だけ置いておきます。いずれも目安で、確約ではありません。

5階層
レビューの降り先
公表資料・仕様・設定・コード・実行結果

10–20人日
初回の典型範囲（目安）
金額は範囲合意後に書面で

4–6週間
典型的な期間
ゲート順。口頭だけで始まる仕事はありません

2営業日
相談メールへのお返事（目標）
自動返信ではなく、人の目を通します

この資料で決まること

- 依頼できる範囲と、お引き受けしない仕事
- 進め方・期間・お客様側の負担の大きさ
- 契約主体と情報の扱い（委託先管理の一次回答）
- 資格・認証について、事実として言えること

この資料では決まらないこと

- 金額 —— 範囲の合意後に書面で提示します。一律の価格表をWebに置かない方針です
- 成果物の保証・脆弱性がゼロであること・規格の取得 —— いずれも約束できません
- 他社との比較評価 —— 範囲と工数を同じ項目で書いたので、突き合わせに使ってください

数値は目安です。遅れる理由は必ず連絡し、中間の論点は都度共有します。

2026年、壊れた箇所は三つに寄っています。

社名や件数を並べることは目的ではありません。設計の問いに戻して読むために、公表された事案を一次資料に紐づけて置いてあります。

供給連鎖 / 月間9,500万DL

境界が、社外に出ていた

LiteLLM の配布物が乗っ取られ、インストールしただけで認証情報が抜かれました。AIエージェント配布物では検体の12%がマルウェアだったという報告も続いています。依存関係の1つが、会社の境界になります。

RCE / CVSS V4.0 9系

ランタイム自体が壊れていた

PHP 本体に認証不要の RCE（PHP2Shell、CVSS v4.0 の9系）。アプリケーションを更新しても、実行環境側の論点として残ります。対象バージョンの読み方まで含めて確認します。

インターネット調査 / 100万台

外から見えていた

公開されているAIサービスを100万台スキャンした調査では、意図していなかった公開面が実測されました。推測ではなく計測の話で、自社資産でも同じ問いが立ちます。

掲載した数値・事案は、それぞれの記事が参照する社告・公式告知・advisory にもとづきます（確認日 2026-10-28）。

LiteLLM が乗っ取られた供給連鎖攻撃の全貌 https://qiita.com/emi_ndk/items/2332ff5c93e63ab736ad
PHP 本体の認証不要 RCE の確認手順 https://qiita.com/emi_ndk/items/503d8fc11a63f2c9453d
100万台のAIサービスをスキャンして見えた運用の実態 https://qiita.com/emi_ndk/items/0aac69d8a962d2413d9d

報告書が棚上げになるのは、階層の途中で止まるからです。

「レビュー」の実力は、どこで止まるかで決まります。私たちは上から順に降りて、各層で確認できたものだけを材料にします。

階層ごとに、止まりやすい形と置きに行くもの（典型）

階層	ここで止まりやすい形	私たちが置きに行くもの
01 公表資料	類似事例の紹介で終わる	事実と報道ベースの切り分け。経営層への説明に使える要約
02 仕様書・BCP	「仕様が推奨しているから直す」	MUST の範囲と、仕様が沈黙している箇所を分けて特定
03 設定	既定値のチェックリスト出力	同じコードで防御が反転する設定を、根拠つきで特定
04 コード	行番号つきの指摘だけ	例外経路と順序まで含めた「効いている」確認と修正方針
05 実行結果	再現の手順書と深刻度	拒否されるはずの要求を実際に送った証拠と回帰テスト案

5階層のうち、2つ以上をまたいだ箇所だけが「直せる指摘」になります。1階層で止まった報告は、次の判断を生みません。

価格は置いていません。
範囲と工数を先に置きます。

同じ「レビュー」でも、階層が2つ違えば別の仕事になります。金額表をWebに置く代わりに、工数・期間・お客様側の負担まで先に公開しています。

10–20人日 / 4–6週間

A. 設計レビュー（範囲固定）

認証・API・権限モデルの設計を、仕様書と呼べる資料がある状態から読みます。リリース判定や調達判断に間に合わせる形です。

5–15人日 / 2–4週間

B. 実装レビュー（範囲固定）

合意した範囲のコード・設定・ログを読み、拒否すべき条件を具体化します。修正後に何を再検証するかまで書きます。

月8–16時間 / 3か月単位

C. 継続アドバイザリー

設計・リリース前のセカンドオピニオンとして残り続けます。判断の記録を残すことで、属人化を減らします。

金額は範囲合意後に見積り（有効期限つき）としてお渡しします。着手せずに終わる相談も歓迎です。契約書のひな形は、こちらの草案でも御社のもので構いません。

ゲート順に進めます。
口頭だけで始まる仕事はありません。

初回の典型フロー（A. 設計レビューを依頼した場合の目安）

時期	実施すること	お客様側	次へ進む条件
Day 0	相談メール（テンプレートを貼り付け可）	懸けられているものを箇条書きで	範囲案とお見積りの前提をお返しします
Day 1–3	60分の打ち合わせ（録音の可否はご相談）	窓口の方お1人	想定範囲と合意事項の草案に同意
Day 3–5	見積り・秘密保持・範囲の書面化	契約手続き	書面の合意をもって着手
週2–4	検証（中間共有つき）	読み取り専用のアクセスを期間限定で	中間の論点共有を受領
週5–6	納品と説明（経営層への同席可）	判定者のご同席	修正方針と優先順位に合意
任意	再検証	修正完了のご連絡	再検証結果の記録をお渡し

修正が終わっていない指摘を「確認しました」とは書きません。再検証まで含めて初めて、クローズになります。

お願いするのは、
週に2時間ほどです。

お1人
窓口の方
情報システム・開発リード、いずれでも構いません

週2回×60分
中間共有
議事と決定記録はこちらで持ちます

読み取り専用
アクセス
期間限定。完了日に削除して記録をお返しします

ご用意いただくもの

- 対象サービスを説明していただける60分
- 設計書・構成図・設定の抜粋（マスキング済みで構いません）
- テスト環境またはログの、どこまでを見るかという範囲
- 判定者の名前（成果物に書いた論点を判断される方）

不要なもの

- 本番の顧客データ・個人情報そのもの
- 認証情報の生値（有効なトークン、平文のパスワード）
- 恒久的な管理者権限、名前の共有されていないアカウント
- 「とりあえず全部見てください」という範囲

いつ・誰に・何の権限を与えたかを記録し、完了日に削除したことを書面でお返しします。

調達と法務が聞くことに、先に答えておきます。

よくある問いへの回答（確認日 2026-10-28）

問い	私たちの回答	第三者に確認できる情報
契約主体はどちらですか	Babushkai（オランダ・ロッテルダム登記）。窓口メールドメインと同一商号の事業者です	KVK 95634347 ／ KVK の公開検索
秘密保持契約は結べますか	はい。範囲の合意前に締結します。口頭だけで始まる仕事はありません	合意書面（草案はこちらでも用意します）
個人情報を扱いますか	原則、扱いません。ログはマスキング・抜粋で受け取ります	「お客様側の負担」の章に書いた受け取り方
再委託はありますか	ありません。作業は代表が単独で行い、契約書に明記します	契約書の条項
情報の保持と削除は	合意した期間だけ保持し、納品日に削除して記録をお渡しします	削除確認の書面
ISMS・ISO/IEC 27001・SOC 2 の状況は	いずれも未取得です。未取得であることを書面に明記します	「証明できる根拠」の章に置いた7件
適格請求書（インボイス）には対応しますか	運営主体名義で請求書を発行します。税務上の区分はこの資料では断定せず、契約前に書面で確認します	請求書・登記情報
連絡経路は真正ですか	babushkai.com は DKIM が有効、DMARC はまだ設定されていません（設定中です）。不審な送信の判別は個別に行います	ドメインの DNS レコード

未取得の規格は、あるふりをして書きません。代替として、どなたでも確認できる根拠を次の章にまとめました。

KVK 公開検索（Babushkai）　https://www.kvk.nl/zoeken/?source=kvk&query=babushkai
脆弱性の開示方針と対応目標　security.babushkai.com/disclosure/
security.txt（RFC 9116）　security.babushkai.com/.well-known/security.txt

AIは速い。
だから、入れない場所を決めます。

読解と下書きに使い、結論には人の名前を残します。顧客の情報をどこに入れるかは、契約の前に決めるべき項目だと考えています。

使う工程

- 一次資料とRFCの横断的な検索と突合
- 読了に時間のかかるコードの下読み
- 負のケース（拒否条件）のテスト案起草
- 報告書の骨子と用語の統一

やらないこと

- 結論・重大度の判断・納品物の責任は人が持つ
- 顧客の生データ・認証情報・ソースを無断で投入しない
- 生成結果をそのまま指摘として書かない
- 道具と制約（モデル・アクセス区分）は報告書に記録する

防御的なセキュリティ作業向けの検証済みモデルアクセス（Anthropic Cyber Verification Program／OpenAI Trusted Access for Cyber）について、自社の事業形——自社スタッフが顧客のシステムに関わり、完成した成果物だけを渡す形——で申請できる経路を確認しています。承認・契約関係は主張しません。

Anthropic Cyber Verification Program（公式） https://www.anthropic.com/news/cyber-verification-program
OpenAI Trusted Access for Cyber（公式） https://learn.chatgpt.com/docs/cyber-safety

資格はまだ持っていません。
その代わり、七つは誰でも確認できます。

情報処理安全確保支援士・OSCP・CISSP・CISM は、この資料の時点で未取得です。それぞれに必要な関門（試験・実務経験・継続教育）も隠していません。

運営主体を特定できます

窓口メールドメイン（babushkai.com）と同一商号の事業者として、オランダ商工会議所の Handelsregister に登記されています（KVK 95634347／ロッテルダム・2024年11月）。商号・住所・業種は公開検索で照会できます。

一次資料つきの技術文章

公表された事案を、各社の社告・公式告知・advisory に紐づけて公開しています。推測は推測として分けて書きました。

仕様の原文引用

RFC 9700（BCP 240）の該当節を原文で引き、MUST の範囲と仕様が沈黙している箇所を分けて示しています。

計測で示した検証

公開されているAIサービスを100万台スキャンし、外から見た自分たちの姿を実測で残しました。

開示方針と窓口

脆弱性を見つけたときの連絡経路・対応目標・やめてほしいことを、相談をはじめる前にお読みいただけます。

機械可読な窓口

RFC 9116 に従った security.txt を /.well-known/ に置き、Contact と有効期限を明記しています。

読み込むのは自ドメインだけ

解析タグ・Cookie・Webフォント・外部スクリプトを読み込みません。このページのソースはそのまま確認できます。

資格を「持っているふり」をしないことは、私たちが指摘の根拠を求めるのと同じ原則です。ロゴ画像も、利用許諾のないものは読み込んでいません。

お引き受けしない仕事を、先に書いておきます。

発注後に使われない成果物を出さないために、合う仕事と合わない仕事を分けて置いてあります。

ご要望と提供者の対応（私たちの立場）

ご要望	たぶん最適な提供者	私たちの立場
網羅性の高い大規模な総当たりテスト	大手診断ベンダー・ツール運用のできるチーム	範囲を絞った設計・実装レビューが得意です。大規模な網羅検査は請けません
ISMS・ISO/IEC 27001 の認証取得支援や内部監査	認証機関・取得支援のできるコンサル	設計の論点として協力できますが、認証そのものは発行できません
24時間365日の監視と一次対応	MSSP・SOC	判断が必要な箇所の相談に残ります。常時待機はしません
形式としての診断報告書（調達要件を満たすため）	要件に合わせた様式を出す提供元	様式だけを満たす目的のお引き受けはしません
経営層と実装チームのあいだで、判断できる形が残らない	——	ここが最も得意な領域です。5階層を降りて、両方の言語で書き直します

稟議で聞かれることに、
そのまま使える言葉で。

経営層からの問い

- 社内のエンジニアでできないのか —— 同じ前提を信じている人が、同じ前提を疑うのは構造的に難しい作業です
- 情報を渡すリスクは —— 個人情報を扱わない設計と、期間限定の読み取り専用アクセスを先に決めます
- いつ効くのか —— 修正方針はリリース判定の前に届く形で出します。再検証まで合意に含めます
- なぜ外部から分かる実績がないのか —— ないものは置いていません。あるのは公開記事と登記だけです

調達・法務からの問い

- 比較見積りに使えるか —— 範囲・工数・期間を同じ項目で書くので、他社案と突き合わせできます
- 単発か継続か —— 初回は範囲固定、以降は任意の継続契約に分けて結べます
- 成果物を監査や審査に使えるか —— 根拠・確認手順・確認日を記録して出せます。規格の証明には使えません
- 契約書のどちらの雛形でもよいか —— はい。ただし結果を保証する条項は技術的に成立しないため、書き換えをご相談します

この章の言葉は、そのまま社内メモに貼り付けてお使いいただけます。出典が必要な行には、同じ資料内のリンクを付けています。

まずは対象と懸念を、
箇条書きでお送りください。

この段階で、秘密情報を共有していただく必要はありません。守りたいもの・心配な点・期限の理由があれば、話を始められます。

1

相談

対象と懸けられているものを、メールで箇条書きでお送りください。秘密情報の共有はこの段階では不要です。

2

範囲の合意

見るもの・見ないもの・許可の範囲・情報の扱い・費用を書面で合意します。口頭だけの開始はしません。

3

検証

5つの階層を降り、確認できた事実と仮説を分けたまま記録します。中間の論点を随時共有します。

4

納品と手当て

経営層向けの要約と、実装チームがそのまま動かせる手順をセットでお渡しし、修正後に再検証します。